

VULNERABILITY ASSESSMENT · SUPPORTING EVIDENCE

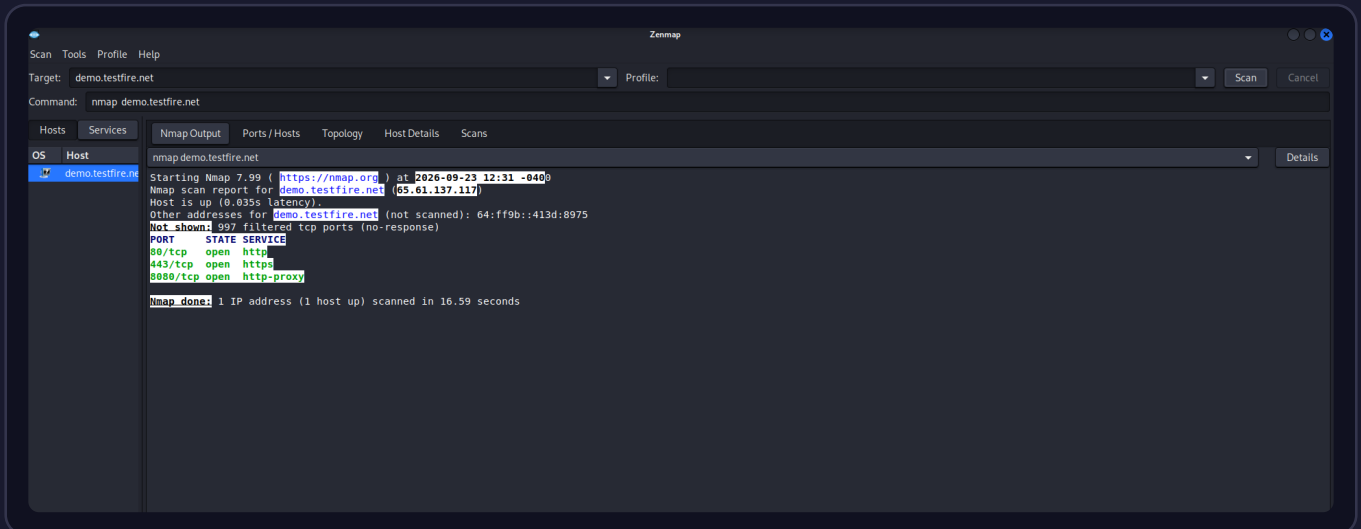
Evidence Appendix

Screenshot evidence collected during the assessment of **demo.testfire.net**, with an explanation of what each screenshot shows and which finding it supports.

4 exhibits · Nmap, Firefox DevTools · September 2026

Open Ports on demo.testfire.net

Zenmap (Nmap GUI) · command: *nmap demo.testfire.net*



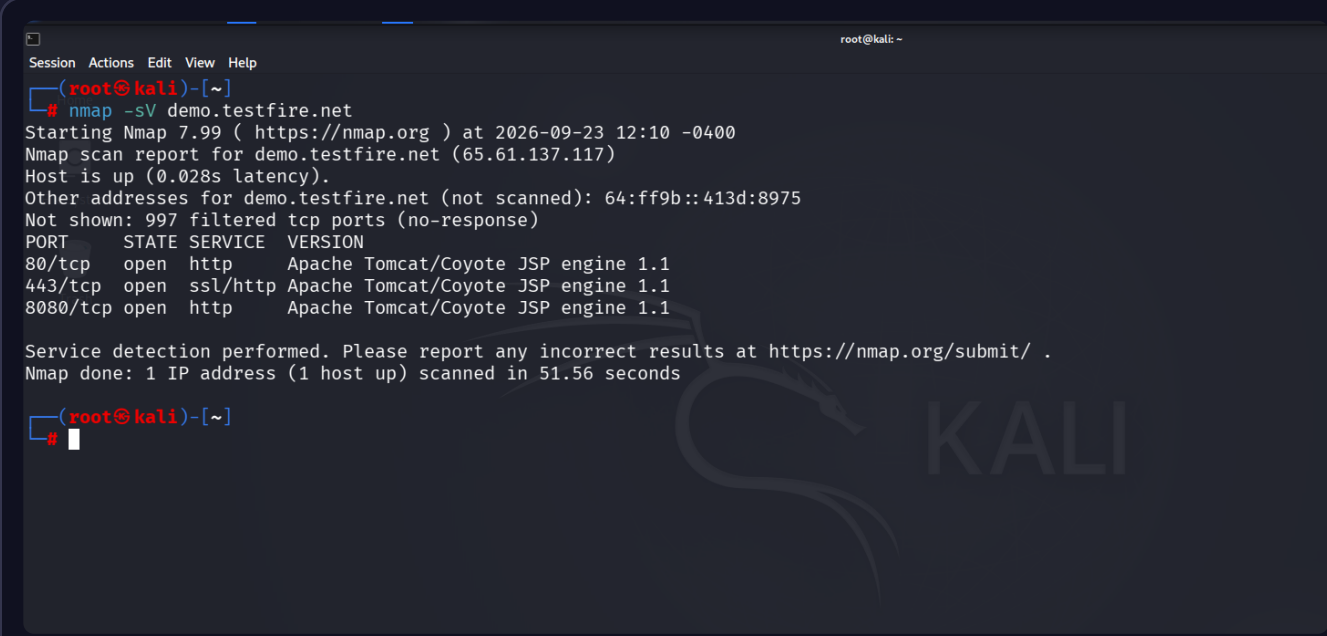
A default Nmap scan against the target host returned three open TCP ports out of 1,000 probed — **80/tcp (http)**, **443/tcp (https)**, and **8080/tcp (http-proxy)** — with the remaining 997 ports filtered (no response). This scan establishes the site's external attack surface: it confirms both an unencrypted (80) and encrypted (443) web service are exposed, plus a secondary proxy port (8080) that is not typically needed on a public-facing host.

SUPPORTS: UNENCRYPTED HTTP PROTOCOL (HIGH)

SUPPORTS: UNNECESSARY OPEN PORT 8080 (LOW)

Software Version Disclosure

Kali Linux terminal · command: *nmap -sV demo.testfire.net*



```
Session Actions Edit View Help
root@kali: ~
(root@kali)-[~]
# nmap -sV demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-23 12:10 -0400
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.028s latency).
Other addresses for demo.testfire.net (not scanned): 64:ff9b::413d:8975
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache Tomcat/Coyote JSP engine 1.1
443/tcp   open  ssl/http Apache Tomcat/Coyote JSP engine 1.1
8080/tcp  open  http    Apache Tomcat/Coyote JSP engine 1.1

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 51.56 seconds

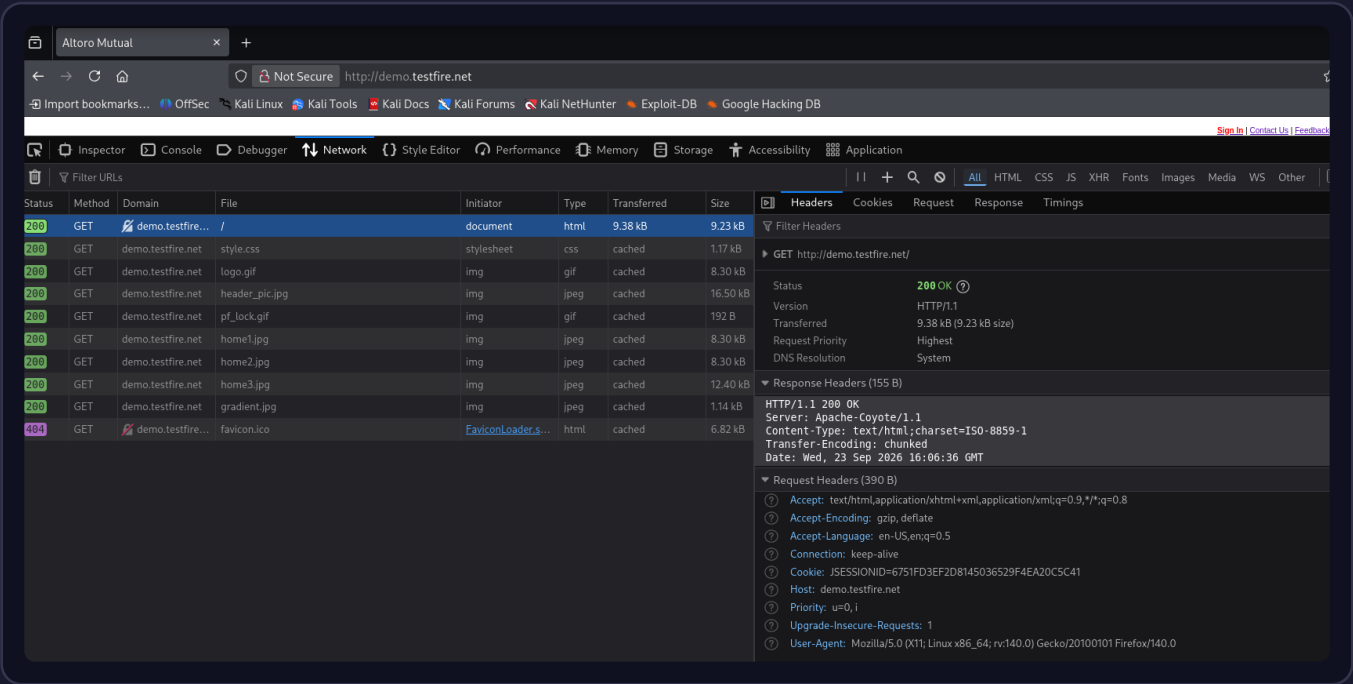
(root@kali)-[~]
#
```

Re-running the scan with the **-sV** (version detection) flag goes further than the basic scan in Exhibit 1: it fingerprints the actual software behind each open port. All three ports (80, 443, 8080) identified themselves as **Apache Tomcat/Coyote JSP engine 1.1**. Publicly broadcasting the exact server software and version gives an attacker a head start — they can look up known weaknesses for that specific release without any guesswork.

SUPPORTS: SERVER VERSION DISCLOSURE (LOW)

Missing Security Headers

Firefox DevTools · Network tab — response to GET http://demo.testfire.net/



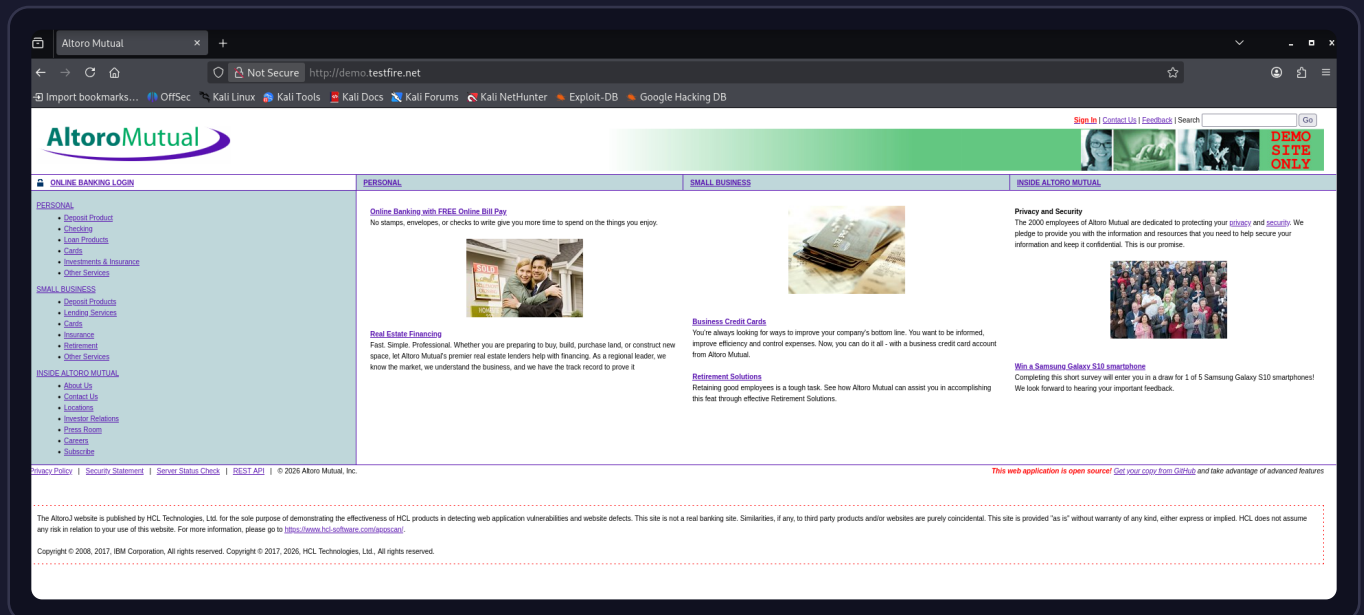
Inspecting the live response headers in the browser (rather than via a port scan) confirms the same **Server: Apache-Coyote/1.1** banner seen in Exhibit 2 — corroborating that finding through a second, independent method. More importantly, the full 155-byte response header set contains no **Content-Security-Policy**, **X-Frame-Options**, or **Strict-Transport-Security** headers. Their absence leaves the page more exposed to clickjacking and cross-site scripting (XSS) attacks.

SUPPORTS: MISSING SECURITY HEADERS (MEDIUM)

CORROBORATES: SERVER VERSION DISCLOSURE (LOW)

Unencrypted Connection

Firefox address bar · <http://demo.testfire.net>



This is the site as an ordinary visitor would experience it. The address bar loads over **http://** rather than **https**, and Firefox itself flags the connection as **“Not Secure”** next to the URL. Because the page is unencrypted, any data exchanged with it — including anything typed into a login or contact form — travels in plain text and can be intercepted by anyone positioned between the user and the server (a man-in-the-middle). This is the clearest, most visible evidence of the assessment's single High-severity finding.

SUPPORTS: UNENCRYPTED HTTP PROTOCOL (HIGH)

Evidence-to-Finding Map

How each exhibit ties back to the Risk Classification table

Exhibit	What It Shows	Finding Supported	Severity
01	Open ports 80, 443, 8080 (Zenmap)	Unencrypted HTTP Protocol / Unnecessary Open Port	High / Low
02	Apache-Coyote/1.1 banner via <i>nmap -sV</i>	Server Version Disclosure	Low
03	Response headers missing CSP / X-Frame-Options / HSTS	Missing Security Headers	Medium
04	Browser "Not Secure" warning on http://	Unencrypted HTTP Protocol	High

Together, these four exhibits provide independent, corroborating evidence for every finding listed in the Risk Classification table of the main report — each observed through at least one tool (Nmap or browser inspection) with no active exploitation performed.